

MUSICMARKT

COMPUTER SECURITY IN NETWORKS AND SYSTEMS

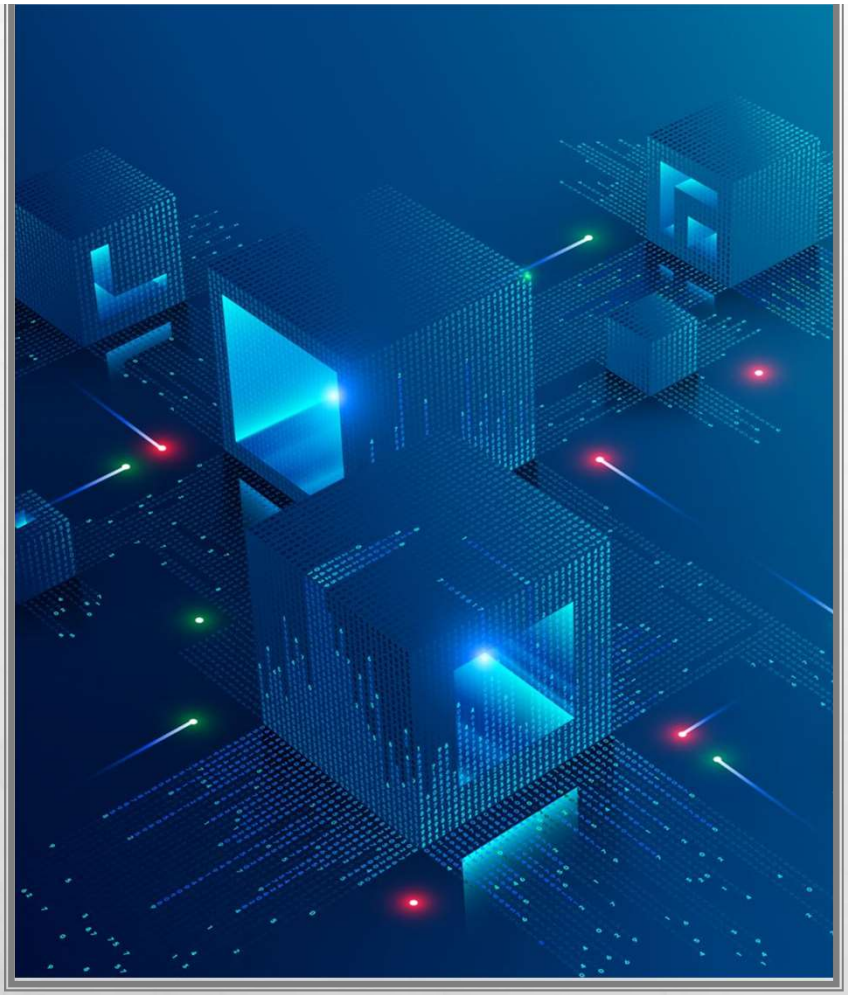
GROUP 9 - ANTÓNIO VENÂNCIO 93689, GUILHERME CARVALHO 96868, MIGUEL GONÇALVES 94238

TÉCNICO LISBOA

TABLE OF CONTENT

- INFRASTRUCTURE
- SECURE CHANNELS AND KEY DISTRIBUTION
- SECURITY CHALLENGE
- SOLUTION WITH PROTOCOL DETAILS
- RESULTS AND CONCLUSIONS



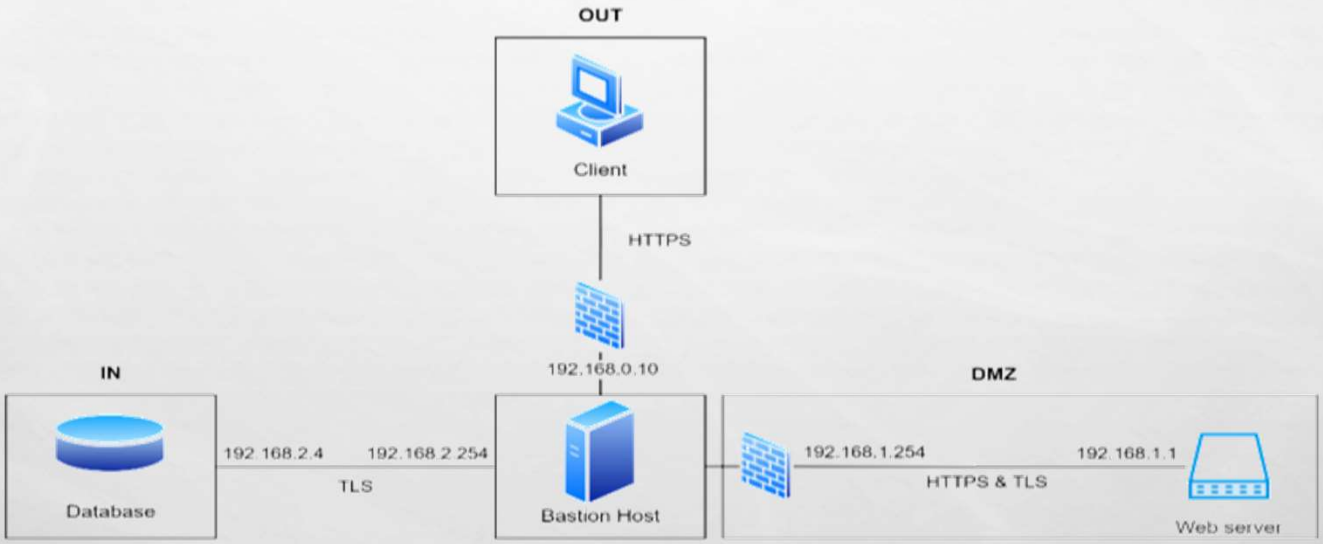


INFRASTRUCTURE OVERVIEW

4 VIRTUAL MACHINES:

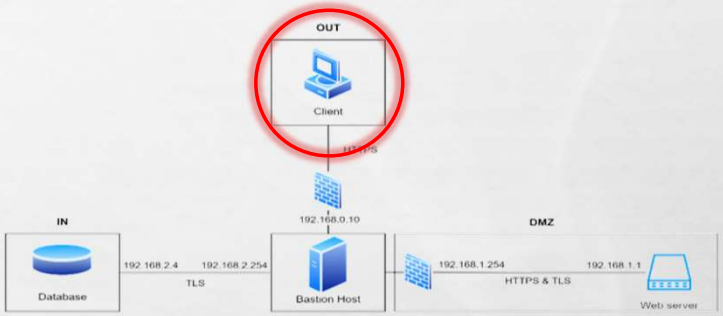
- CLIENT
- BASTION HOST
- WEBSERVER (FLASK)
- DATABASE (MYSQL)

INFRASTRUCTURE OVERVIEW



SECURE CHANNELS AND KEY DISTRIBUTION

THE CLIENT:

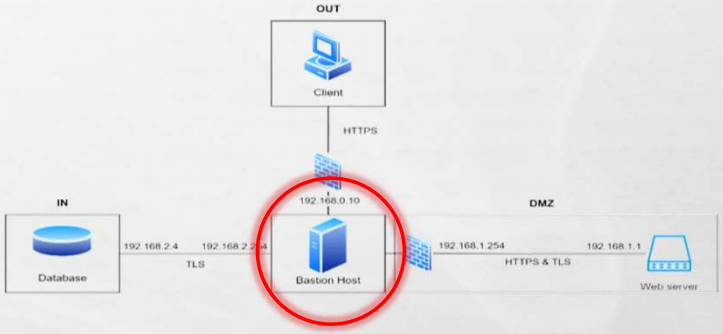


- ONLY OPENS HTTPS CONNECTIONS (PORT 443) TO THE BASTION HOST
- CLIENT IS ONLY AWARE OF THE EXISTENCE OF THE BASTION HOST (KNOWS THE EXTERNAL IP ADDRESS OF IT)

SECURE CHANNELS AND KEY DISTRIBUTION

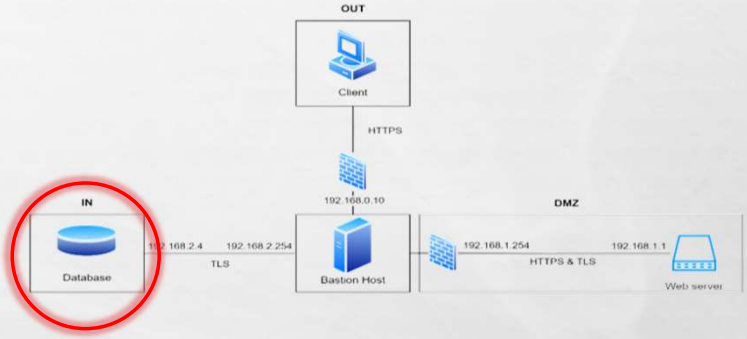
THE BASTION HOST:

- HTTPS CONNECTIONS FROM THE INTERNAL AND EXTERNAL NETWORK (PORT 443) ARE REDIRECTED TO THE WEB SERVER (192.168.1.1)
- INCOMING TRAFFIC DIRECTED TO 192.168.2.4 ON THE SQL PORT (3306) IS ONLY ACCEPTED IF ORIGINATED FROM THE WEBSERVER (192.168.1.1)
- ALL OTHER INCOMING TRAFFIC IS REJECTED



SECURE CHANNELS AND KEY DISTRIBUTION

THE DATABASE:

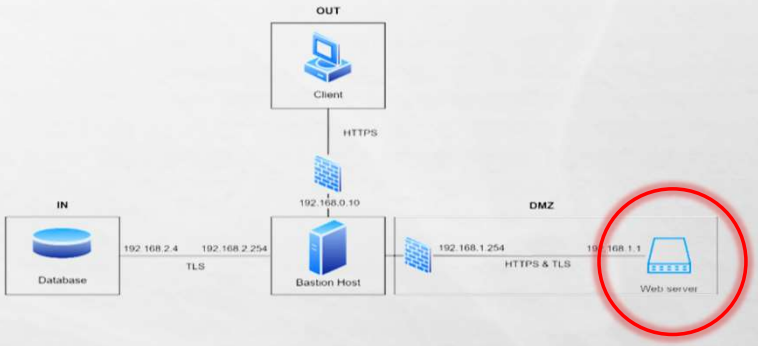


- RECEIVES SQL QUERIES
- SENDS SQL RESPONSES

SECURE CHANNELS AND KEY DISTRIBUTION

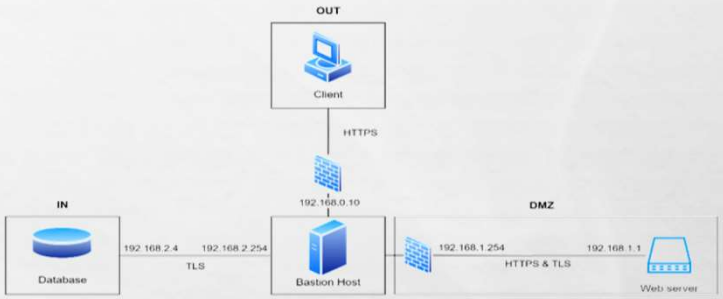
THE WEB SERVER:

- INSIDE DMZ
- ACCEPTS INCOMING HTTPS CONNECTIONS
- DOES NOT START NEW CONNECTIONS



SECURE CHANNELS AND KEY DISTRIBUTION

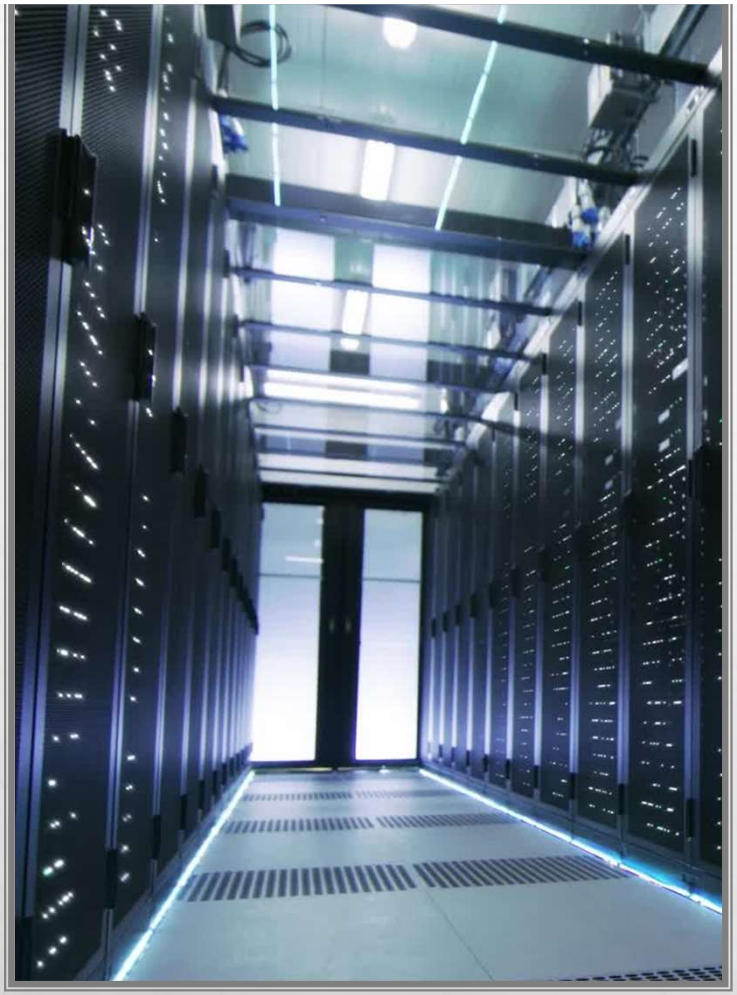
KEY DISTRIBUTION:



SELF SIGNED CERTIFICATE AND KEY TO REPRESENT THE CA.

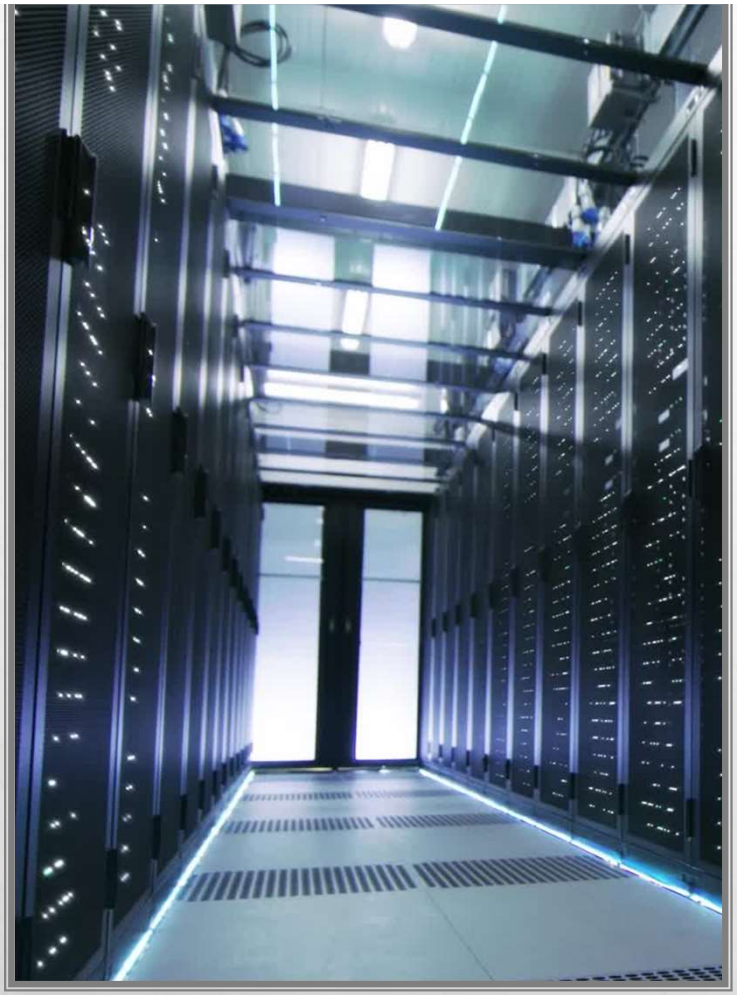
TWO PAIR OF KEYS (PUBLIC/PRIVATE)

- ONE FOR THE WEB SERVER
- ONE FOR THE DATABASE



SECURITY CHALLENGE

"IN MUSICMARKT, EACH USER HAS AN ACCOUNT THAT CONTAINS PERSONAL INFORMATION TO FACILITATE FUTURE ORDERS. THE ACCESS TO THE USERS' ACCOUNTS MUST BE CORRECTLY AUTHENTICATED USING ALSO THE USER'S MOBILE DEVICE."



SECURITY CHALLENGE

REQUIREMENTS TO IMPLEMENT:

- VALIDATE AUTHENTICITY
- AVOID COMPROMISE OF PERSONAL INFORMATION THAT IS STORED IN THE DATABASE.
- PREVENT BRUTE FORCE ATTACKS
- PROVIDE CONNECTION FRESHNESS (BOTH IN LOGIN AND 2FA AUTHENTICATION).
- PREVENT REPLAY ATTACKS

SOLUTION AND PROTOCOL



ATTACKER SECURITY BREACHING:

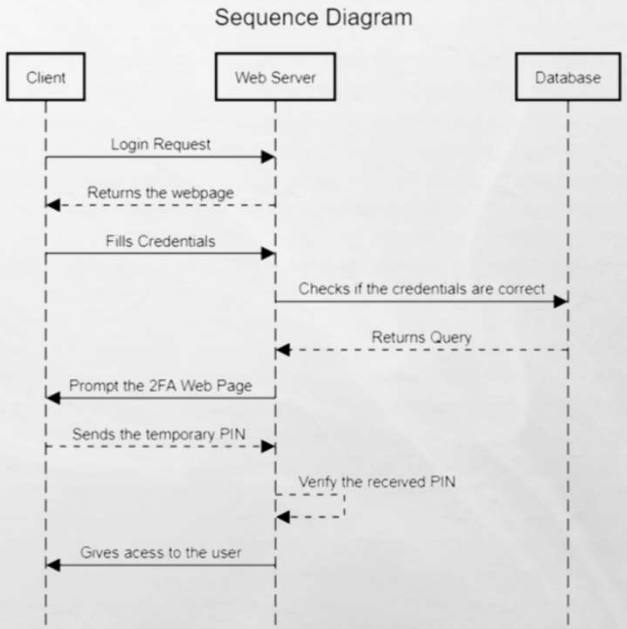
- PASSING THE FIREWALLS.
- SUCCESSFULLY IMPERSONATING A USER. (MOST CRITICAL) :
  - GETTING CREDENTIALS
  - BRUTE FORCE ATTACKS
  - REPLAY ATTACKS

PROPOSED SOLUTION

1. THE DATABASE WILL CONTAIN THE USERNAME, THE PASSWORD, THE CELLPHONE NUMBER, AND THE SALT USED TO HASH ITS PASSWORD. ENSURE SAFETY IN CASE OF DATABASE LEAKS AND OFFLINE ATTACKS.

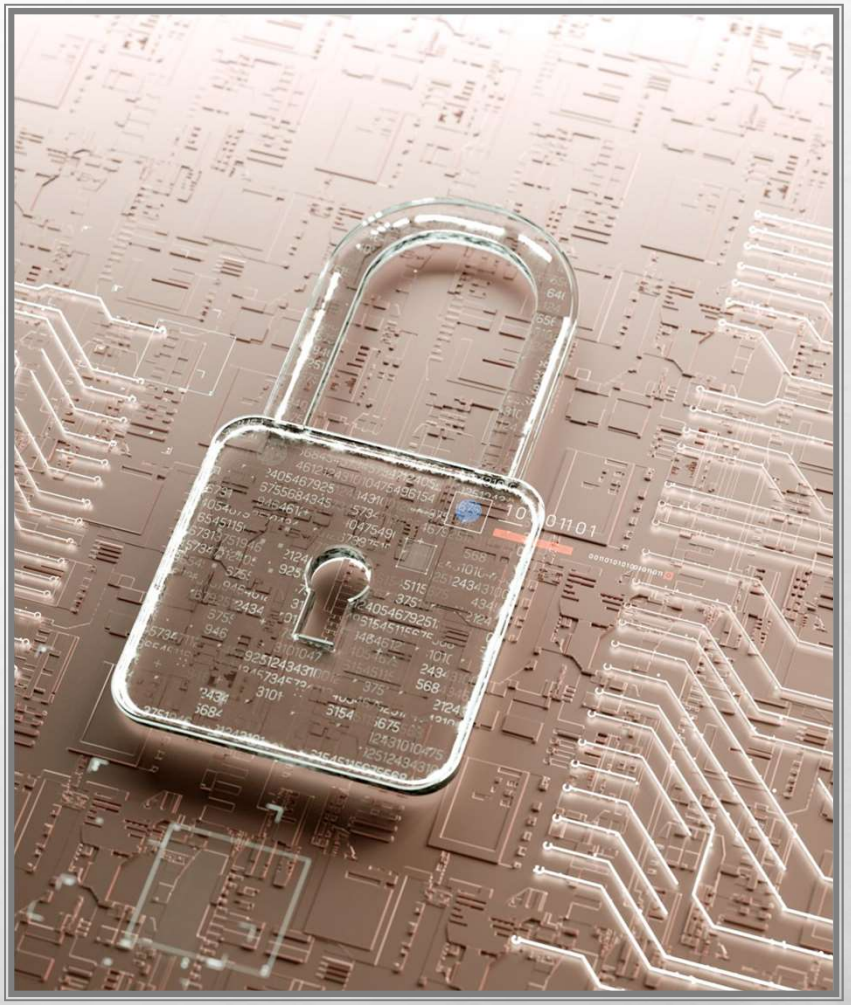
1. INITIAL AUTHENTICATION IS DONE IN THE BROWSER, BY ASKING USERNAME AND PASSWORD. TO PREVENT BRUTE FORCE, IMPOSE LIMIT OF ATTEMPTS TO LOGIN. IF IT REACHES THE LIMIT, BLOCK LOGIN FOR A CERTAIN AMOUNT OF TIME.

1. SIMULATE A SECOND DEVICE IN POSSESSION OF THE USER, WITH 6-DIGIT PIN. CLIENT RUNS THE "APPLICATION" THAT GENERATES THE TEMPORARY PIN AND SUBMITS IT IN THE 2FA PROMPT PAGE. THE PIN HAS A TIME LIMIT. IT ALSO HAS A LIMIT OF ATTEMPTS TO CORRECTLY SUBMIT THE PIN. PROVIDES AUTHENTICITY AND FRESHNESS.



SOLUTION TOOLS

- OPENSSL – OPEN-SOURCE FOR CERTIFICATES GENERATION USED IN VARIOUS PKI ACTIVITIES.
- FLASK – EASINESS ON IMPLEMENTATION A FUNCTIONAL WEBSERVER
- MYSQL – USER FRIENDLY AND COMPATIBILITY WITH FLASK WEBSERVERS
- HASHLIB – STANDARD FOR HASHING AND CYPHER.(SHA-256 USED)
- VM VIRTUALBOX – EMULATION OF SEPARATE MACHINES



RESULTS

- VALIDATE AUTHENTICITY
- AVOID COMPROMISE OF PERSONAL INFORMATION THAT IS STORED IN THE DATABASE
- PREVENT BRUTE FORCE ATTACKS
- PROVIDE CONNECTION FRESHNESS (BOTH IN LOGIN AND 2FA AUTHENTICATION)
- PREVENT REPLAY ATTACKS

- PARTIAL - THERE'S AN ISSUE THAT ALLOWS A POSSIBLE ATTACKER TO USE THE COOKIES TO GET ACCESS TO THE PIN
- SATISFIED - HASHED CREDENTIALS IN THE DATABASE, PREVENTING THE DAMAGE FROM A DATABASE LEAK
- SATISFIED – 3 ATTEMPTS BEFORE LOCK OUT.
- SATISFIED - 2FA HAS A TIME LIMIT OF 20 SECONDS. IN CASE OF FAILURE, WEB SERVER TERMINATES THE SESSION. THIS PIN IS NOT THE SAME BETWEEN SESSIONS (TIME BASED).
- SATISFIED - COMBINATION OF SESSIONS AND TIME LIMIT TO SUBMIT THE PIN

CONCLUSIONS

MANAGED TO MAINTAIN 2 IMPORTANT ASPECTS NEEDED: FRESHNESS AND AUTHENTICITY.

ENSURED THE PROTECTION OF DATA, USING HASHES, SECURE CHANNELS, AND PUBLIC/PRIVATE KEYS.

HOWEVER, THE PROJECT CAN BE ENHANCED IN THE FUTURE. FOR EXAMPLE:

- ONLINE BRUTE FORCE ATTACKS: EXPONENTIAL LOCK-OUT TIME FOR LOGGING FAILURES AND WARNING THE USER OF THE LOGGING ATTEMPTS BY E-MAIL/SMS.
- SECURE CHANNEL FOR SHARING SECRET KEY WITH USER APPLICATION.
- INCREASE THE NUMBER OF WEB SERVERS TAKING REQUESTS. (OUT OF THE SCOPE OF PROJECT, SEVERAL WEB SERVERS TO DEAL WITH MANY REQUESTS AT A GIVEN TIME. WOULD HELP DIMINISH THE EFFECTS OF A POSSIBLE DOS AND DDOS ATTACKS).




LIVE DEMONSTRATION